



Next-Cycle Planning Brief

Nemesis AI · brainstorm + continuous review · planning Tuesday

Date: 2026-06-09 · **Facilitator:** Claude (brainstorm + review) · **Owner:** Rishabh

Inputs: 12-week roadmap (W3–W12) · the security/QA audit · the Remediation Re-test feature · lab work.

At a glance — 17 viable ideas added to the backlog; **6 (+1 stretch)** selected for next cycle, **100% with scope + acceptance criteria**; this Tuesday's review pass caught **3 defects, 0 escaped to QA** (all fixed).

1 · Brainstorm → enhancement backlog

Score = quick RICE-ish gut (Reach×Impact / Effort), 1–5. Selected items marked **SEL** · **STRETCH**

ID	Idea	Theme	Why it's good	Eff	Score	
CI-1	CI on every PR (tsc + vitest + lint) + remote git	Ops	Unblocks every cycle KPI — no PR-turnaround / rework / defect-escape metric without it	M	5	SEL
CI-2	ESLint config + lint script (server + client)	Ops	Prereq for CI-1; auto-catches a defect class → raises review effectiveness	S	4	SEL
SP-1	Scan Profiles — Quick / Standard / Thorough	UX	Solves the felt pain (865 cases unusable; env-hacking); first-class run-intensity control	M	5	SEL
EV-1	Evaluator P/R/F1 calibration behind EVAL_PROMPT_VERSION	Accuracy	Cuts false positives we observed (clean refusal marked fail); W2 golden snapshots guard it	M	4	SEL
SEC-1	H-05 — refresh token → HttpOnly cookie	Security	Closes the last deferred High from the audit; removes XSS-exfil of the long-lived token	M	4	SEL
TR-1	Per-agent run history + posture trend	UX	Pairs with Re-test — show whether each scan improved/regressed; CISO-facing	M	4	SEL
LAB-1	Dockerize DVRAG into compose + 2 new vuln classes	Demo	Reliable one-command lab + richer target; high demo leverage, low effort	S	4	STR
RR-1	Detector tier-1 hardening + LLM-judge fallback (W6)	Accuracy	Lowers detector false-positive rate (benign slice)	M	3	
RR-2	Turn on SUITE_RELEVANCE_LLM_RERANK, measured (W4)	Accuracy	Validate relevance re-rank with a real before/after	S	3	
ML-1	Multilingual into high-tier strategy families (W7)	Accuracy	Broadens coverage by ≥2 unique families	M	3	
EX-1	Findings export — CSV / JSON / SARIF	Integrations	Drops findings into Jira / GitHub code-scanning	S	3	
SCH-1	Scheduled re-verification + regression alert	UX/Ops	Auto re-test findings on a cadence; webhook on regression	M	3	

INT-1	Slack + SIEM webhooks w/ "Send test" (W10)	Integrations	Push run / critical-finding events to ops tooling	M	3	
PIL-1	Pilot install runbook + RC tag (W12)	Pilot	Gates "pilot-ready"; depends on CI-1	M	3	
OBS-1	Grafana dashboard JSON + alerts for nemesis_* metrics	Ops	Makes W2 observability actionable	S	2	
SEC-2	M-04 DNS-rebinding IP pinning	Security	Hardens the SSRF TOCTOU (partly mitigated today)	M	2	
REL-1	M-08 cancellation: batch poll + cancel-check before reporting	Reliability	Removes per-case N+1; respects late cancels	S	2	

2 · Selected next-cycle items — scope + acceptance criteria

Goal: 100% of these leave today with testable acceptance criteria. Each is one independently-shippable PR.

CI-1 + CI-2 — CI pipeline + lint (Ops · M)

In: `ci.yml` running `tsc` + `vitest` + `lint` (server) and `tsc-b` + `lint` + `build` (client) on PRs; ESLint + `lint` scripts; remote + branch-protect `main`. **Out:** deploy-on-merge, coverage gates, mass reformat (don't touch engine / W2 golden snapshots).

Acceptance: ☐ PR triggers CI; green check required to merge · ☐ `npm run lint` passes both packages (max-warnings 0) · ☐ 119 server tests + client build run; a broken PR goes red · ☐ `origin` exists, `main` protected.

SP-1 — Scan Profiles (Quick / Standard / Thorough) (UX · M)

In: `run-tests` accepts `profile`; pure `profileToConfig()` (tier thresholds + chain depth) threaded per-run; UI selector + est. count; profile stored on the run + shown on the report. **Out:** per-category selection; changing the default (default = standard == today).

Acceptance: ☐ quick ≈ 1 case/probe, thorough largest; unit test on `profileToConfig()` · ☐ default byte-identical to today (back-compat test) · ☐ UI shows profile + est. count pre-run; profile appears on the report.

EV-1 — Evaluator calibration (Accuracy · M · depends on W2 golden — done)

In: `EVAL_PROMPT_VERSION` flag (default = current); a v2 prompt tuned for fewer false-positives; `bench:eval` reporting P/R/F1 v1 vs v2 + a ship decision. **Out:** rewriting the verdict engine; expanding the labeled set beyond ~50.

Acceptance: ☐ `bench:eval` prints v1 vs v2 macro-P/R/F1 + a recorded decision in `bench.json` · ☐ v2 improves ≥ 1 of {P,R,F1} by ≥ 5% with none regressing below baseline, OR is explicitly not shipped · ☐ default unchanged unless flag set; W2 golden green/intentionally refreshed.

SEC-1 — H-05 refresh token → HttpOnly cookie (Security · M)

In: server sets `cv_rt` HttpOnly/Secure/SameSite=Strict on login/verify/refresh; `/auth/refresh` reads cookie-or-body; logout clears it; client stops persisting `cv_refresh`. **Out:** moving the access token out of localStorage (follow-up); SSO cookie redesign.

Acceptance: ☐ after login the refresh token is NOT in localStorage; `cv_rt` HttpOnly cookie set · ☐ silent refresh after access-token expiry works via cookie; logout invalidates · ☐ verified locally end-to-end before any prod deploy; tests green.

TR-1 — Run history + posture trend (UX · M)

In: per-agent "History" list (date, profile, risk score, fails) + risk-over-time sparkline + Δ vs previous run (introduced / resolved by `externalId`). **Out:** cross-agent org rollups; CSV export.

Acceptance: ☐ agent detail shows ≥ 2 prior runs with a risk trend · ☐ selecting two runs shows "introduced N / resolved M" by `externalId` · ☐ no new DB tables.

LAB-1 ★ (stretch) — Dockerize DVRAG + 2 vuln classes (Demo · S)

Acceptance: ☐ `docker compose --profile lab up` starts DVRAG on :4001 · ☐ two new vuln classes (tool-call SSRF, upload-borne indirect injection) leak under attack · ☐ README updated.

3 · This Tuesday's review pass

Fresh-eyes correctness + security review of the just-shipped work (Remediation Re-test + the riskiest audit fixes).
Defects caught in review: 3 — all fixed pre-QA (0 escaped).

Sev	Defect	Status
MED	Re-verify delta dropped <code>error</code> /missing re-tests from both buckets → "Resolved X of Y" + green all-clear could mislead an operator about whether the fix held	✓ fixed — added <code>unevaluated</code> bucket + gated all-clear
LOW	<code>/reverify/:runId</code> with no <code>?parent=</code> fired <code>GET /test-runs//results</code>	✓ fixed — guard added
LOW	IPv4-mapped IPv6 (<code>::ffff:169.254.*</code>) bypassed metadata block in relaxed SSRF mode	✓ fixed — normalize + block

Verified-correct (no change): `async/override-aware` `requirePermission` , H-03 MFA grace math, M-02 MFA lockout, the cartesian pre-built-case execution path, the C-02 TC-NNN remap. Verdict: **fix-then-ship** → **shipped**. Server `tsc` + 119 tests + client `tsc` green.

4 · Making the KPIs measurable

Most KPIs are un-measurable until CI-1 lands — that's why it's the #1 pick.

KPI	How we measure it	This Tuesday
Viable ideas added / selected	This brief + a <code>backlog.md</code>	17 added / 6 (+1) selected
% items leaving Tuesday scoped	§2 scope + acceptance criteria	100% (6/6)
PR review turnaround	GitHub PR created→first-review (after CI-1); target < 1 business day	pending CI-1
Defects caught vs escaped to QA	Label review-found vs QA-found defects	3 caught / 0 escaped
Rework rate	% PRs needing ≥2 review rounds (after CI-1)	pending CI-1